ESPECIFICACIÓN DE REQUISITOS DE SOFTWARE

BIMetrics

Entrega 3 · Seguridad, autenticación y cierre

Versión 1.1 · 9 de noviembre de 2026

Este documento especifica el control de acceso de BIMetrics y cómo verificarlo. También define los entregables de cierre y los casos de uso que se demostrarán ante el docente.

1. Propósito y alcance

BIMetrics organiza presupuestos de obra con partidas, cantidades y precios de referencia en pesos colombianos. Para esta entrega se evalúan el registro y el inicio de sesión, la protección de rutas, la autorización por roles, la documentación de la API y la demostración de los casos de la Entrega 1.

1.1 Fuentes de los requisitos

Origen	Alcance que aporta
Entrega 1	Casos CU-01 a CU-04. Catálogo, cálculo, exportación e historial.
Entrega 2	Datos documentales de actividad BIM, CRUD y consulta combinada SQL y NoSQL.
Entrega 3	Hash de contraseñas, sesión o JWT, dos o más niveles de acceso, API documentada y repositorio reproducible con imágenes de ejecución.

1.2 Organización del SRS

2. Contexto, actores y restricciones · 3. Requisitos de seguridad · 4. Casos de uso de cierre · 5. Interfaces y errores · 6. Trazabilidad y verificación · 7. Entregables y criterios de cierre.

Repositorio y README de la rama de entrega · Índice de evidencias

02 / DESCRIPCIÓN GENERAL

Contexto, actores y restricciones

2.1 Arquitectura de referencia

React y Vite proporcionan la interfaz web. Flask expone la API y ejecuta las reglas de autorización y cálculo. SQLite almacena proyectos y presupuestos. MySQL aloja el catálogo maestro en la configuración habitual. MongoDB guarda identidades, preferencias y actividad BIM. La modalidad local admite un catálogo SQLite.

Actor	Responsabilidad y límite de acceso
Visitante	Puede registrarse o iniciar sesión. Las rutas privadas requieren una sesión válida.
Arquitectura e ingeniería	Gestionan los presupuestos de los proyectos a los que tienen acceso. Pueden consultar el catálogo.
Cliente	Consulta los recursos a los que tiene acceso. Las escrituras de catálogo y presupuesto se rechazan.
Administrador	Mantiene el catálogo maestro y gestiona cuentas. Las rutas de proyecto comprueban el acceso al recurso.
Docente	Evalúa el sistema con cuentas de prueba, el contrato de la API, el UML y las evidencias publicadas.

2.2 Reglas y supuestos

RN-01. Los importes se expresan en COP. El subtotal de una partida es cantidad por precio unitario aplicado. El AIU se calcula sobre el costo directo.

RN-02. En una importación BIM, se analiza un TXT exportado de Revit o Archicad y el usuario valida cada coincidencia. La API aplica el precio de referencia del catálogo.

RN-03. Los datos de prueba serán ficticios. La configuración real de las bases requiere credenciales y acceso de red fuera del repositorio.

UML de casos de uso · Arquitectura de persistencia

03 / REQUISITOS FUNCIONALES

Seguridad y acceso

RF-01 · Registro de usuario

Requisito. El sistema deberá registrar cuentas con nombre, correo, contraseña, rol permitido y consentimiento. Deberá almacenar un hash de la contraseña en MongoDB.

Criterio de aceptación. Con datos válidos, el registro responde HTTP 201. El perfil devuelto carece de contraseña y hash. El registro público rechaza la autoasignación del rol administrador.

RF-02 · Inicio y cierre de sesión

Requisito. El sistema deberá comparar la contraseña con su hash y establecer una sesión firmada por Flask tras autenticar. Deberá permitir cerrar la sesión.

Criterio de aceptación. Las credenciales válidas devuelven HTTP 200 y una cookie de sesión. Una credencial incorrecta recibe 401. Después del cierre, una petición a una ruta privada recibe 401.

RF-03 · Protección de rutas privadas

Requisito. La API deberá exigir una sesión válida antes de devolver los datos de proyectos, presupuestos y actividad privada.

Criterio de aceptación. GET /api/proyectos sin cookie devuelve 401. Con sesión válida, responde 200 con los proyectos visibles para esa cuenta.

RF-04 · Permisos por rol y recurso

Requisito. El sistema deberá distinguir permisos de cliente, equipo técnico y administración. La autorización de un proyecto deberá considerar la propiedad o colaboración.

Criterio de aceptación. El cliente recibe 403 al intentar modificar el catálogo. El administrador crea una partida con 201. Una cuenta sin acceso al proyecto recibe 404 al solicitar el presupuesto privado.

RNF-01 · Protección de sesión y configuración

Requisito. Las escrituras deberán exigir un origen permitido. La cookie deberá usar HttpOnly y SameSite=Lax. La configuración de producción deberá exigir una cookie Secure y una clave de sesión de al menos 32 caracteres.

Criterio de aceptación. Una escritura sin origen permitido devuelve 403. El arranque de producción con la cookie insegura se rechaza. Las credenciales se cargan mediante variables privadas.

04 / REQUISITOS FUNCIONALES

Casos de uso de la Entrega 1

La demostración parte de cuentas y datos ficticios. Se registra el resultado de cada caso y se señala la diferencia con la propuesta original.

ID y origen	Requisito y aceptación	Alcance original pendiente
RF-05 **CU-01** Catálogo	La API deberá permitir al administrador crear, consultar, editar y eliminar una partida de prueba. Se esperan HTTP 201, 200, 200 y 204.	Formulario de administración del catálogo para arquitectura.
RF-06 **CU-02** Presupuesto	El sistema deberá guardar cantidades y precios aplicados y calcular el costo directo y el AIU. Para 20 m a $45.000 COP/m y AIU de 20 %, el total será $1.080.000 COP.	Agrupación por capítulos y flujo específico de insumos inactivos.
RF-07 **CU-03** Documentos	La aplicación deberá permitir descargar un presupuesto accesible como PDF, DOCX y XLSX. Las tres rutas deberán devolver HTTP 200 y archivos legibles.	Firma digital certificada, tabla por capítulos y reintento automático.
RF-08 **CU-04** Historial	La API deberá consultar el historial de un proyecto y duplicar un presupuesto autorizado. La consulta posterior deberá incluir el original y la copia.	Filtros por cliente o fecha, duplicación como nueva obra y ajuste masivo.

4.1 Secuencia sugerida

1. Probar una ruta sin sesión. 2. Iniciar sesión como administrador y probar catálogo. 3. Crear obra, presupuesto y AIU. 4. Descargar archivos. 5. Duplicar y revisar historial. 6. Iniciar como cliente y comprobar el rechazo de una escritura.

4.2 Condición para cerrar el alcance original

La evidencia demuestra los cuatro casos en la versión actual. La cobertura de todos los pasos originales requiere implementar los pendientes o acordar el alcance actualizado con el docente.

Trazabilidad detallada con la Entrega 1 · Capturas de ejecución

05 / INTERFACES

Contrato y dependencias

5.1 Interfaz de usuario y API

La aplicación se abre en **http://localhost:5173**. La API local usa **http://127.0.0.1:5000/api**. El cliente mantiene la cookie entre solicitudes. Las escrituras envían Origin y usan JSON, salvo el formulario multipart para importar TXT. Las exportaciones devuelven archivos.

Operación	Interfaz y respuesta esperada
Registro y sesión	POST /auth/registro (201); POST /auth/login (200); GET /auth/sesion (200 o 401); POST /auth/logout (200).
Catálogo	GET /partidas; POST /partidas; PUT y DELETE /partidas/{codigo}. Los cambios requieren rol administrador.
Proyecto y cálculo	GET o POST /proyectos; POST /presupuestos; POST /presupuestos/{id}/partidas; PUT /presupuestos/{id}/aiu.
Documentos e historial	GET /presupuestos/{id}/pdf, /word o /excel; GET /proyectos/{id}/presupuestos; POST /presupuestos/{id}/duplicar.
Actividad y resumen	POST /actividades-bim; GET, PUT o DELETE /actividades-bim/{id}; GET /dashboard/resumen.

5.2 Errores y salud

401 sesión ausente o credenciales rechazadas. **403** permiso u origen no autorizado. **404** recurso inexistente o inaccesible. **503** dependencia no disponible. **GET /api/salud/mongodb** comprueba la conexión documental con un ping.

5.3 Documento normativo de interfaz

RF-09. El repositorio deberá incluir un contrato OpenAPI con rutas, métodos, parámetros, cuerpos, respuestas y el esquema de autenticación por cookie. **Aceptación.** El validador debe aceptar el contrato y el docente debe poder localizar las rutas de la demostración.

Contrato OpenAPI completo · Guía de acceso a la API

06 / VERIFICACIÓN

Matriz de trazabilidad

Origen y requisito	Verificación	Evidencia y estado
Entrega 3 RF-01, RF-02	Registrar, autenticar y cerrar sesión; comprobar la cookie y rechazar credenciales inválidas.	Pruebas del backend y estados de API. La validación de credenciales también respondió contra Atlas.
Entrega 3 RF-03, RF-04, RNF-01	Consultar sin sesión, probar escritura con cliente y comprobar el origen de la solicitud.	HTTP 401, 403 y 404 verificados. Configuración de producción comprobada por pruebas.
Entrega 1 RF-05 a RF-08	Demostrar catálogo, cálculo, descarga e historial con una obra de prueba.	Cuatro casos verificados en el alcance actual. Los pasos originales pendientes se listan en la sección 4.
Entrega 2 RF-10	Crear, leer, editar y eliminar una actividad. Verificar métricas SQL y última actividad en la misma respuesta.	CRUD y dashboard comprobados con MongoDB simulado. Conexión de BIMetrics al clúster real verificada por separado.
Entrega 3 RF-09 y RE-01	Validar el OpenAPI y comprobar que el repositorio contiene instrucciones e imágenes.	OpenAPI válido. README, UML y capturas disponibles en la rama de entrega.

6.1 Requisito de continuidad de la Entrega 2

RF-10. El sistema deberá permitir CRUD de actividad BIM y devolver en GET /api/dashboard/resumen métricas de SQL junto con perfil y última actividad de MongoDB. **Aceptación.** Crear y actualizar un evento ficticio, comprobar que el resumen combina ambos orígenes y obtener 404 al leer el evento eliminado.

6.2 Verificación registrada

El backend pasó 31 pruebas en el cierre y GitHub Actions aprobó backend y frontend en la revisión de dependencias. La API respondió 200 en la prueba de Atlas real. La suite automatizada usó SQLite en memoria y MongoDB simulado.

Resultados de API · CRUD y dashboard aislados · Atlas en vivo

07 / PAQUETE DE ENTREGA

Criterios de cierre y anexos

7.1 Repositorio reproducible

RE-01. La entrega deberá incluir un repositorio público con instrucciones de instalación y ejecución, documentación técnica, UML y evidencia visual. **Aceptación.** Desde el README se debe poder ubicar la versión evaluable, identificar las dependencias, iniciar los servicios y seguir el guion de demostración.

Entregable	Dónde revisarlo
Repositorio y guía de ejecución	README de la rama de entrega
Documentación técnica de API	Contrato OpenAPI y guía de control de acceso
Modelo de casos de uso	Diagrama UML de BIMetrics
Continuidad de la Entrega 2	PDF de persistencia políglota y matriz de trazabilidad
Imágenes y respuestas de ejecución	Índice de evidencias

7.2 Resultado de cierre

La evidencia acredita autenticación, sesiones, autorización por roles, documentación de la API y la demostración de los cuatro casos con el alcance actual. Para acreditar el alcance original completo, quedan las diferencias de la sección 4. La conexión real a Atlas está acreditada. El CRUD documental y la respuesta mixta en Atlas siguen pendientes de evidencia en vivo.

7.3 Referencia de estructura

NASA Software Engineering Handbook · Software Requirements Specification